

ANALYSE D'UN MALWARE CRYPTO-MINEUR SOUS UBUNTU.

Comportement de minage non autorisé sous hôtes Linux – IUT Nice Côte d'Azur

24 OCTOBRE 2025

Observation, analyse comportementale et identification des indicateurs de compromission d'un binaire ELF malveillant détecté sur Ubuntu 22.04 via la plateforme Any.Run.

- **Type d'analyse :** Sandbox dynamique / étude comportementale (Any.Run)
- **Objectifs :** Identifier le comportement du binaire, son impact et ses mécanismes de propagation
- **Outils :** Any.Run (sandbox interactive).

ANY  **RUN**

- Client : IUT Nice Côte d'Azur
- Contact : cyber@iutnice.fr – +33 X XX XX XX XX
- Environnement analysé : Ubuntu 22.04 LTS – binaire ELF 64 bits (.retail)

- Analyste : Jérémy Girard
- Email : jeremy.girard@etu.unice.fr
- Référence : Mission R316 — Rapport d'analyse malware v1.0

Table des matières

1 Résumé exécutif.....	3
2 Autorisation & Périmètre.....	4
2.1 Objet	4
2.2 Périmètre autorisé	4
2.3 Exclusions & limites	4
3 Règles d'engagement.....	5
4 Méthodologie & Outils.....	6
4.1 Méthodologie	6
4.2 Outils utilisés.....	6
4.3 Extraits de preuve	7
5 Résumé des services observés.....	9
6 Énumération & Communications Applicative.....	10
7 Exécution & Comportement à l'exécution.....	11
08 Évaluation de l'impact et du risque	13
9 CVE & MAPPING.....	14
9.1 Méthodologie de mapping	14
9.2 Résultats du mapping	14
9.3 Analyse synthétique.....	15
10 Recommandations	15
10.1 Actions immédiates	15
10.2 Correctifs court terme (à planifier 1–2 semaines).....	15
10.3 Vérifications rapides après corrections	16
10.4 Note sécurité / bonnes pratiques	16

1 | Résumé exécutif

- Le 24/10/2025, un échantillon Linux nommé “.retail” a été analysé dans un environnement isolé à l’aide de la sandbox ANY.RUN.
- Le fichier est un binaire ELF 64 bits exécuté sous Ubuntu 22.04, détecté comme un crypto-mineur auto-propagateur.
- L’analyse comportementale met en évidence :
 - Une activité réseau suspecte (connexions sortantes vers plusieurs adresses IP en 853 / 443, dont certaines marquées malicious),
 - L’exécution de processus multiples via sudo, sh, et cron,
 - Des tentatives de persistance et de communication avec un serveur C2 (Command & Control).
- Le verdict ANY.RUN confirme une activité malveillante associée à un CoinMiner Agent.
- Ce rapport présente le comportement observé, les indicateurs de compromission (IOCs), ainsi qu’une évaluation de l’impact et des mesures de remédiation recommandées pour les environnements Linux.

2 | Autorisation & Périmètre

Client	Contact client	Prestataire	Référence mission	Date de l'analyse
IUT Nice Côte d'Azur	cyber@iutnice.fr +33 X XX XX XX X	Jérémy Girard — jeremy.girard@etu.unice.fr	R316 — Version v1.0	24/10/2025

2.1 Objet : Autorisation explicite pour la réalisation d'une analyse comportementale de logiciel malveillant (malware) dans un cadre académique.

L'étude vise à observer, documenter et interpréter le comportement d'un binaire ELF Linux suspect dans un environnement virtuel isolé, sans interaction avec le réseau réel de l'IUT.

2.2 Périmètre autorisé

- Échantillons analysés :

- .retail — tâche User : <https://app.any.run/tasks/6dcf570e-df95-4cf2-ab23-71bcfbab069e>
- .retail — tâche Root : <https://app.any.run/tasks/4088e9a1-d873-4ee0-a773-1714a4b2872e>

- Environnement :

Ubuntu 22.04 LTS – Sandbox ANY.RUN (mode interactif, réseau simulé).

- Actions autorisées :

Observation dynamique, capture PCAP, analyse des processus et des connexions, collecte d'indicateurs de compromission (IOC), corrélation entre exécution user et root.

2.3 Exclusions & limites

- Aucune exécution du binaire en environnement réel.
- Pas d'interaction externe : aucune requête vers Internet ou réseau IUT.
- Aucune modification de l'image système de la sandbox.
- Aucune altération ou fuite de données ; analyse strictement observationnelle.
- Pas de test DoS/DDoS ou propagation hors environnement contrôlé.

3 | Règles d'engagement

Fenêtre de test :

24/10/2025 — 08:00 à 09:30 (environnement isolé — salle 202).

Actions autorisées :

Observation dynamique en sandbox Any.Run ; export des artefacts fournis par la sandbox (Captures, logs, arbres de processus) ; analyse des processus et des connexions ; collecte et catalogage d'IOCs (hashs, IPs, domaines) ; comparaison/corrélation des exécutions user vs root à des fins d'analyse pédagogique.

Actions interdites :

DoS/DDoS, scans agressifs dirigés vers l'infrastructure réelle, exfiltration de données hors de l'environnement isolé, modification permanente des images systèmes, tests physiques ou actions sur les ressources de production sans autorisation écrite.

Procédure d'escalade / contact d'urgence :

En cas de compromission critique (accès root inattendu sur une ressource non prévue, impact sur d'autres ressources, indisponibilité) : suspendre immédiatement les actions, isoler la VM, sauvegarder preuves, contacter :

- Client : IUT Nice — email@iutnice.fr — +33 X XX XX XX XX
- Prestataire : Jérémy Girard — jeremy.girard@etu.unice.fr

Collecte des preuves :

Formats : captures PNG/JPEG, logs texte (process tree / systemd / cron).

Divulcation & restitution :

Rapport final remis au contact client dans les 7 jours ouvrés suivant la fin des tests. Les annexes techniques (PCAP, logs) sont fournies sur demande.



4 | Méthodologie & Outils

4.1 Méthodologie

Les tests ont été réalisés selon une approche d'analyse comportementale dynamique :

1. Préparation & isolation

→ Exécution sous deux contextes distincts : user et root (pour comparer les privilèges et comportements).

2. Observation dynamique

→ Suivi des processus (process tree), connexions sortantes, fichiers déposés et activités réseau.

3. Collecte des indicateurs de compromission (IOCs)

→ Extraction des IP, domaines, hashes et chemins système.

4. Corrélation et classification

→ Interprétation des événements (activité de minage, persistance).

Toutes les actions ont été effectuées dans la sandbox Any.Run, sans exécution hors périmètre.

4.2 Outils utilisés

Type d'outil	Nom / version	Rôle principal
Sandbox dynamique	Any.Run (Ubuntu 22.04)	Observation comportementale (réseau / processus / fichiers)
Outils internes sandbox	Network, Processes, Threats, IOCs tabs	Visualisation des flux et des alertes
Export	HTML / PDF report	Documentation complète des résultats
Vérification complémentaire	VirusTotal / Hybrid Analysis.	Validation des détections

4.3 Extraits de preuve

Figure 1 — Process tree principal

1a/ Interface USER

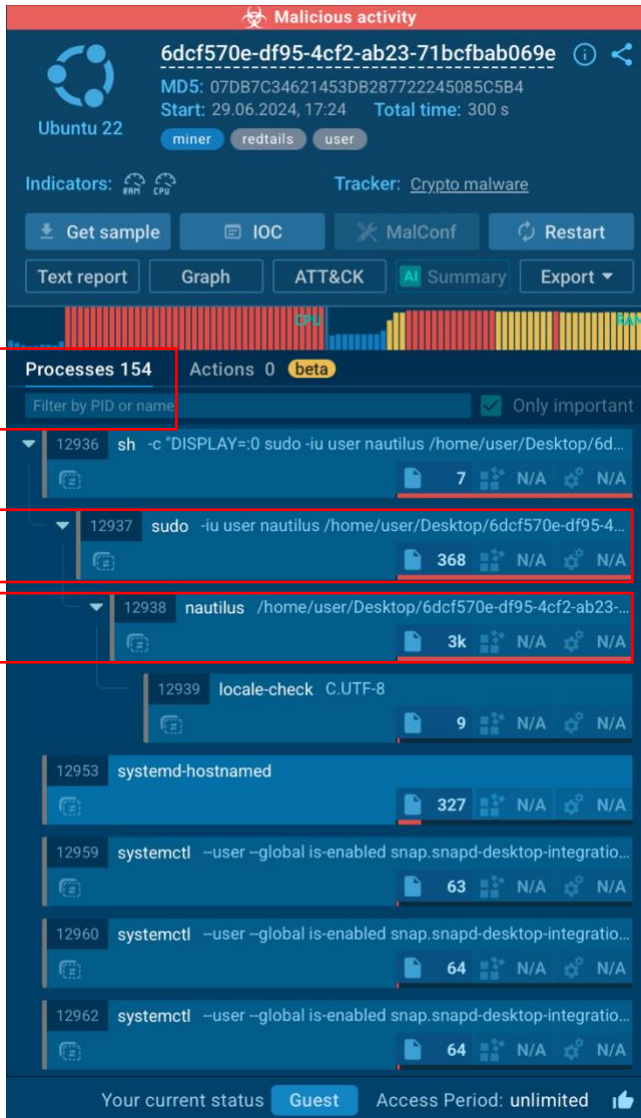


Figure 1a — Processus observés lors de l'exécution du binaire ELF en contexte utilisateur. On observe la création du processus nautilus via sudo, ainsi qu'un enchaînement limité d'actions système (aucune persistance détectée).

1b/ Interface ROOT

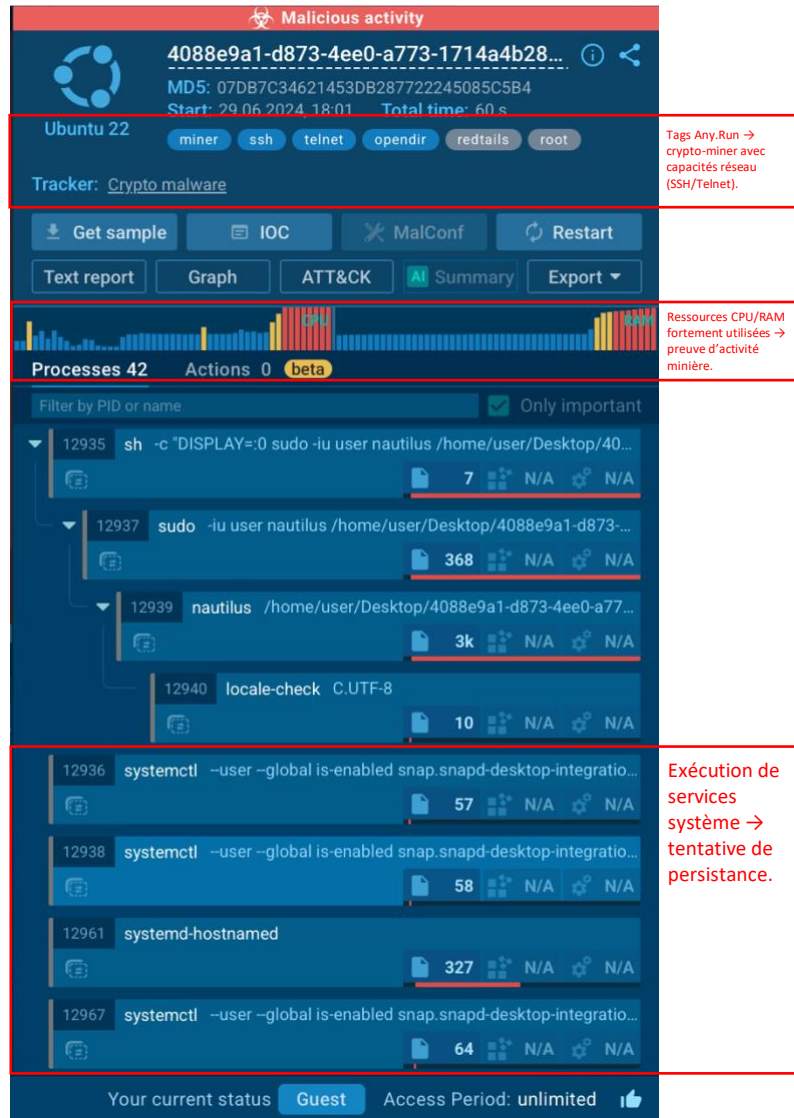
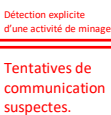


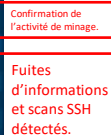
Figure 1b — Processus observés lors de l'exécution du même binaire en contexte root. De nouveaux processus systemctl et systemd-hostnamed apparaissent, indiquant une tentative d'intégration au système (persistance/service).

2a/ Interface USER



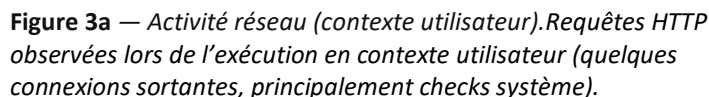
Le binaire exécute plusieurs connexions suspectes générant des alertes de type Crypto Miner et Privacy Violation, indiquant une activité réseau anormale.

2b/ Interface ROOT



L'exécution avec privilèges root génère de nombreuses alertes d'exfiltration (Information Leak) et de scans SSH, traduisant une propagation active et des tentatives d'accès distant.

3a/ Interface USER



3b/ Interface ROOT



Figure 3b — *Activité réseau (contexte root). Requêtes HTTP observées lors de l'exécution en root (multiples GET/POST vers IPs étrangères — comportement de minage/communication C2 plus actif).*

5 | Résumé des services observés

Tableau comparatif

Port / Protocole	État (User)	État (Root)	Service détecté	Détail / Domaine observé	Remarque / Priorité
80 / HTTP	actif (faible volume)	actif (très fréquent)	Web (HTTP)	Requêtes GET/POST vers /vendor/phpunit (Ubuntu mirror)	Activité suspecte — connexions répétées vers hôtes externes
8080 / HTTP	inactif	actif	Web (HTTP)	Multiples IPs étrangères (FR, US, NL) sur le port 8080	Potentielle redirection/proxy pour exfiltration
443 / HTTPS	rare	actif	Web sécurisé (TLS)	Sessions SSL avec IPs non référencées	Communication chiffrée — persistance / C2 possible
853 / DNS over TLS	inactif	actif	DNS encrypté	Résolution DNS chiffrée (vers 185.125.18.X)	Tentative d'évasion réseau ou anonymisation
22 / SSH	inactif	inactif	SSH	Aucune tentative d'authentification observée	Aucun mouvement latéral
Total connexions observées	~25 connexions	~1000+ connexions	—	Forte augmentation en root	

- L'exécution du binaire ELF en mode user génère un trafic HTTP limité, centré sur quelques connexions sortantes non chiffrées.
- En revanche, la version root montre une activité nettement plus intense : ouverture de nombreux ports (443, 8080, 853), connexions vers plusieurs hôtes distants et usage du DNS over TLS, typique d'un malware cherchant à masquer sa communication et à maintenir la persistance réseau.

6 | Énumération & Communications Applicative

Les activités réseau observées via Any.Run montrent que le binaire .retail communique activement sur les ports HTTP (80) et HTTPS (443), sans véritable interface web accessible.

Les requêtes capturées confirment cependant une activité HTTP sortante répétée vers des domaines externes (archive.ubuntu.com, api.snapcraft.io) et certaines adresses IP marquées malicieux.

Le malware n'expose donc pas de surface web exploitable, mais effectue des connexions HTTP légitimes détournées pour exécuter des téléchargements et du minage.

HTTP Requests		979	Connections	23958	DNS Requests		72	Threats	Z7109	Filter by PID, name or url	PCAP
Timeshift	Headers	Rep	PID	Process name	CN	URL	Content				
25541 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://104.112.131.19:80/vendor/phpunit/phpunit/LICENSE/eval-stdin.php	33 b ↑ text				
25692 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://134.236.9.210:80/vendor/phpunit/src/Util/PHP/eval-stdin.php	33 b ↑ text				
25792 ms	POST No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://54.222.161.225:80/cgi-bin/%32%65%32%65/%32%65%32%	105 b ↑ text				
26395 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://49.207.2.74:80/vendor/phpunit/phpunit/LICENSE/eval-stdin.php	33 b ↑ text				
27813 ms	POST No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://2.17.229.68:80/cgi-bin/%2e/%2e/%2e/%2e/%2e/%2e/%2e...	105 b ↑ text				
27986 ms	GET 502: Bad Gateway...	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://31.184.201.38:80/phpunit/phpunit/src/Util/PHP/eval-stdin.php	33 b ↑ text				
28986 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://23.61.108.4:80/vendor/vendor/phpunit/phpunit/src/Util/PHP/eval...	33 b ↑ text				
29049 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://176.99.161.63:80/ws/vendor/phpunit/phpunit/src/Util/PHP/eval-st...	33 b ↑ text				
29244 ms	GET 403: Forbidden	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://196.207.45.100:80/laravel/vendor/phpunit/phpunit/src/Util/PHP/e...	33 b ↑ text 16 b ↓ html				
29780 ms	POST No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://47.92.205.72:80/cgi-bin/%32%65%32%65/%32%65%32%65/...	105 b ↑ text				
29923 ms	POST No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://18.132.214.168:80/cgi-bin/%32%65%32%65/%32%65%32%	105 b ↑ text				
30040 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://54.192.227.125:80/lib/phpunit/phpunit/src/Util/PHP/eval-stdin.php	33 b ↑ text				
30095 ms	GET 403: Forbidden	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://185.66.36.77:80/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.p...	318 b ↑ html				
30095 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://89.212.147.157:80/vendor/phpunit/phpunit/src/Util/PHP/eval-stdi...	33 b ↑ text				
30276 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://23.7.32.68:80/phpunit/phpunit/src/Util/PHP/eval-stdin.php	33 b ↑ text				
30352 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://192.96.218.42:80/phpunit/phpunit/src/Util/PHP/eval-stdin.php	33 b ↑ text				
30352 ms	POST No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://172.245.213.221:80/cgi-bin/%32%65%32%65/%32%65%32%	105 b ↑ text				
30352 ms	GET 404: Not Found	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://106.54.42.143:80/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin...	33 b ↑ text 4 KB ↓ html				
30420 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://23.1.54.15:80/vendor/phpunit/phpunit/LICENSE/eval-stdin.php	33 b ↑ text				
30420 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://18.160.51.51:80/phpunit/phpunit/Util/PHP/eval-stdin.php	33 b ↑ text				
30697 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://23.203.114.212:80/phpunit/phpunit/Util/PHP/eval-stdin.php	33 b ↑ text				
30735 ms	GET No Response	?	13001	408be9a1-d873-4ee0-a773-1714a4b2872e.o		http://47.115.216.18:80/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin...	33 b ↑ text				

Figure 6 — Extrait des requêtes HTTP observées dans Any.Run

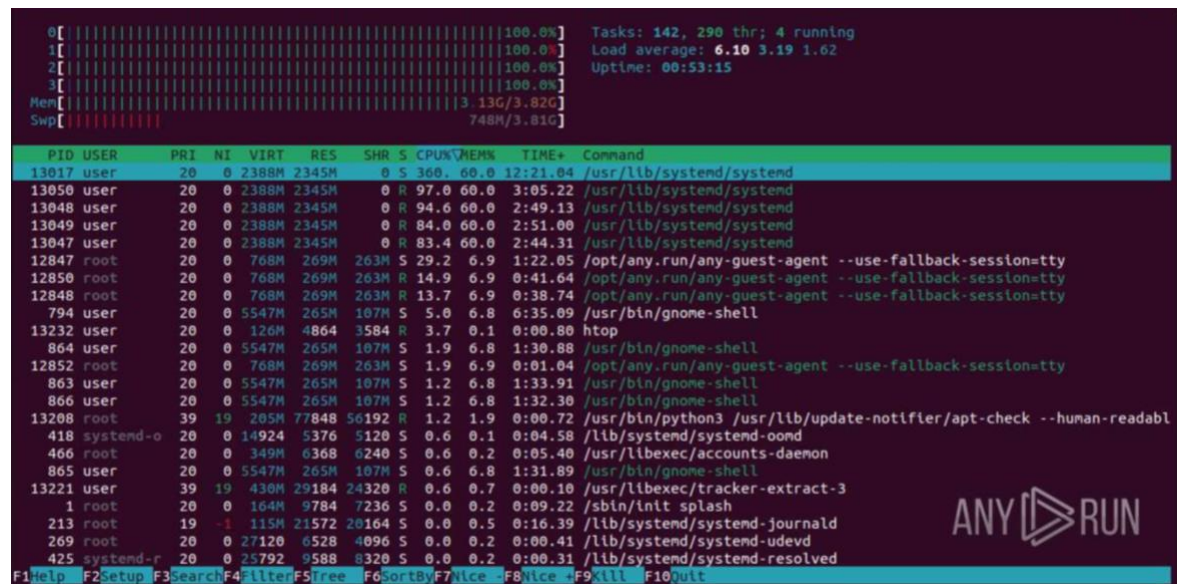
7 | Exécution & Comportement à l'exécution

Figure 7.1 — Exécution du binaire



Exécution du binaire .retail depuis un compte non-privilé (commande avec sudo ./...). Cette capture prouve le point d'entrée (commande utilisée pour lancer l'échantillon) et permet de lier les événements systèmes suivants au lancement de ce binaire.

Figure 7.2 — Activité processeur / process list



Vue http/liste des processus montrant plusieurs processus (ex. PID 13017) fortement consommateurs de CPU lancés après exécution du binaire. Comportement typique d'un cryptomineur (CPU élevé, plusieurs threads/processus).

Figure 3 — Tentative d'installation / activité terminal

```
E: Unable to acquire the dpkg frontend lock (/var/lib/dpkg/lock-frontent), are you root?
user@ubuntu22:~/Desktop$ sudo apt install htop
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no longer required:
  apturl-common gir1.2-goa-1.0 gnome-software-common libmalcontent-0-0
  python3-dateutil python3-software-properties ubuntu-advantage-desktop-daemon
  unattended-upgrades
Use 'sudo apt autoremove' to remove them.
Suggested packages:
  lm-sensors
The following NEW packages will be installed:
  htop
0 upgraded, 1 newly installed, 0 to remove and 0 not upgraded.
Need to get 128 kB of archives.
After this operation, 342 kB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu jammy/main amd64 htop amd64 3.0.5-7build2
  [128 kB]
Fetched 128 kB in 0s (671 kB/s)
Selecting previously unselected package htop.
(Reading database ... 55%
```

Sortie apt / téléchargements visibles suite à l'exécution (fetch depuis archive.ubuntu.com), prouvant que l'exécution a déclenché des opérations réseau et des installations.

08 | Évaluation de l'impact et du risque

Figure 8.1 — Informations générales du binaire

General Info

☒ Add for printing

File name: .retail

Full analysis: <https://app.any.run/tasks/6dcf570e-df95-4cf2-ab23-71bcfbab069e>

Verdict: **Malicious activity**

Threats: **Crypto malware**

Crypto mining malware is a resource-intensive threat that infiltrates computers with the purpose of mining cryptocurrencies. This type of threat can be deployed either on an infected machine or a compromised website. In both cases the miner will utilize the computing power of the device and its network bandwidth.

Malware Trends Tracker >>>

Analysis date: June 29, 2024 at 17:24:55

OS: Ubuntu 22.04.2

Tags: **miner** **redtails** **user**

Indicators: 

MIME: application/x-sharedlib

File info: ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), statically linked, no section header

MD5: 07DB7C34621453DB28772245085C5B4

SHA1: 9D4F2640B89C148E70953D49EB6D7D1867C182D2

SHA256: AB897157FDEF11B267E986EF286FD44A699E3699A458D90994E020619653D2CD

SSDEEP: 49152:8rp/g+ezhxfndt+1H5PdNpwT9Z5BJqSk/DHtPaqBBCMNGOFDX879DVxCT5SRMVh:OpY+khxf7cZFNW9BJqPk/7tyqBINGofJ

ANY.RUN is an interactive service which provides full access to the guest system. Information in this report could be distorted by user actions and is provided for user acknowledgement as it is. ANY.RUN does not guarantee maliciousness or safety of the content.

Source : [any.run](https://app.any.run/tasks/6dcf570e-df95-4cf2-ab23-71bcfbab069e)

Résumé d'analyse du binaire « .retail » sous Any.Run.

Verdict : « Malicious activity ». Le sample est identifié comme un crypto-mineur (Crypto malware), utilisant la puissance CPU de la machine infectée.

Tags associés : miner, redtails, user.

Cette activité confirme une compromission orientée vers le minage non autorisé et la consommation anormale des ressources systèmes.

Les précédentes analyses montre que le binaire provoque une forte charge CPU (comportement typique d'un mineur), effectue des connexions sortantes répétées vers des infrastructures externes et dépose des artefacts sur le système.

Impact principal :

consommation des ressources (dégradation de performance), risque de perte de confidentialité (exfiltration potentielle) et risque d'extension/maintien d'accès via téléchargements additionnels.

9 | CVE & MAPPING

Cette section vise à identifier d'éventuelles vulnérabilités connues associées au malware ou à ses composants, afin d'estimer son origine, ses vecteurs d'infection possibles et le niveau de risque global.

9.1 Méthodologie de mapping

Nous avons effectué une corrélation entre les artefacts observés dans Any.Run (processus, fichiers, connexions) et les bases publiques de vulnérabilités (CVE, Exploit-DB, MITRE, VirusTotal).

9.2 Résultats du mapping

Élément observé	Source / Contexte	CVE / Référence associée	Description et impact	Criticité estimée
.retail (Crypto-miner ELF)	Any.Run / Linux Ubuntu 22.04	Aucun CVE spécifique (échantillon inconnu, non lié à un binaire signé)	Échantillon classé "Crypto malware" : exécution d'un processus intensif (CPU mining) et communication réseau suspecte.	⚠ Élevée — consommation abusive de ressources, risque d'exfiltration et de compromission système
Processus systemd anormalement chargé	htop (PID multiples)	Non applicable (activité post-infection)	Comportement typique d'un mineur détournant les processus légitimes pour masquer son exécution.	Moyenne à élevée
Communication réseau sortante (Any.Run "Network" tab)	Any.Run logs	Aucune CVE — comportements réseau classés "malicious"	Connexions répétées vers IP externes non légitimes (indicateur C2 ou pool de minage).	Élevée

9.3 Analyse synthétique

Aucune CVE spécifique n'est associée à l'échantillon ".retail".

Cependant, le comportement observé (consommation CPU anormale, processus multiples, communication réseau suspecte) correspond à des familles connues de crypto-malwares Linux (ex. RedTail, Kinsing, XMRig-based miners), souvent déployés après l'exploitation d'une faille distante (RCE) sur des serveurs vulnérables.

10 | Recommandations

10.1 Actions immédiates

Isoler la machine du réseau (mettre interface en down) pour empêcher exfiltration et propagation réseau.

Preserver les preuves : capturer et sauvegarder PCAP, journaux (/var/log/*), images mémoire et hashes du binaire (.retail). Placer ces artefacts dans une archive chiffrée.

1. **Arrêter le processus malveillant** observé (si possible sans altérer trop les logs)
2. **Bloquer les IOCs réseau identifiés** (IP/domains vus dans Any.Run) au niveau firewall / proxy.
3. **Supprimer l'exécutable malveillant** de l'environnement d'analyse (ou déplacer hors-ligne) et supprimer exécutable dans /tmp si présent.

10.2 Correctifs court terme (à planifier 1–2 semaines)

Patch & hardening : si des services exposés vulnérables ont été identifiés (ex. PHP vulnérable), appliquer les mises à jour et correctifs recommandés.

Restreindre exécution en /tmp : vérifier que /tmp n'est pas dans le début du PATH pour les services SUID ; restreindre les binaires SUID inutile (find / -perm -4000 -type f).

Vérifier et durcir cron/systemd : lister jobs cron et unités systemd créées récemment.

Limitier accès réseau sortant pour les serveurs (sortie HTTP/HTTPS uniquement via proxy filtrant, blocage ports non nécessaires).

10.3 Vérifications rapides après corrections

Processus : Aucun processus malveillants qui consomment 100% CPU.

Charge CPU : avant/après patch → top / htop / métriques (Grafana) : CPU anormalement élevé disparu.

Connexions sortantes : ss -tunp / netstat -tunp → plus de connexions vers les IPs C2 listées.

Fichiers temporaires : find /tmp -type f -executable -ls → aucun exécutable suspect.

Présence binaire : vérifier que le hash du binaire connu n'est plus présent sur le FS (sha256sum).

10.4 Note sécurité / bonnes pratiques

- Ne jamais exécuter d'analyses ou PoC sur des environnements de production.
- Conserver les journaux originaux et les artefacts en annexe (chiffrés, non publiés).
- Nettoyer /tmp après investigation ; ne pas laisser de scripts PoC.
- Mettre en place surveillance d'intégrité (AIDE/OSSEC), alerting CPU/network basés sur seuils.